

Контроль доступа и журналирование

Цели и функции системы

Контроль доступа

Обеспечивает **конфиденциальность** и целостность данных. Предотвращает несанкционированные действия в системе путем жесткой регламентации прав.

Журналирование

Обеспечивает **подотчетность** и возможность расследования. Фиксирует все значимые события для последующего анализа и выявления аномалий.

Этапы предоставления доступа (AAA)

Идентификация

**Аутентификаци
я**

Авторизация

Аудит

«Кто ты?»

Заявление о себе

«Докажи!»

Подтверждение
личности

«Что можно?»

Определение прав

«Что сделал?»

Фиксация действий

Многофакторная аутентификация (MFA)



Комбинация факторов защиты

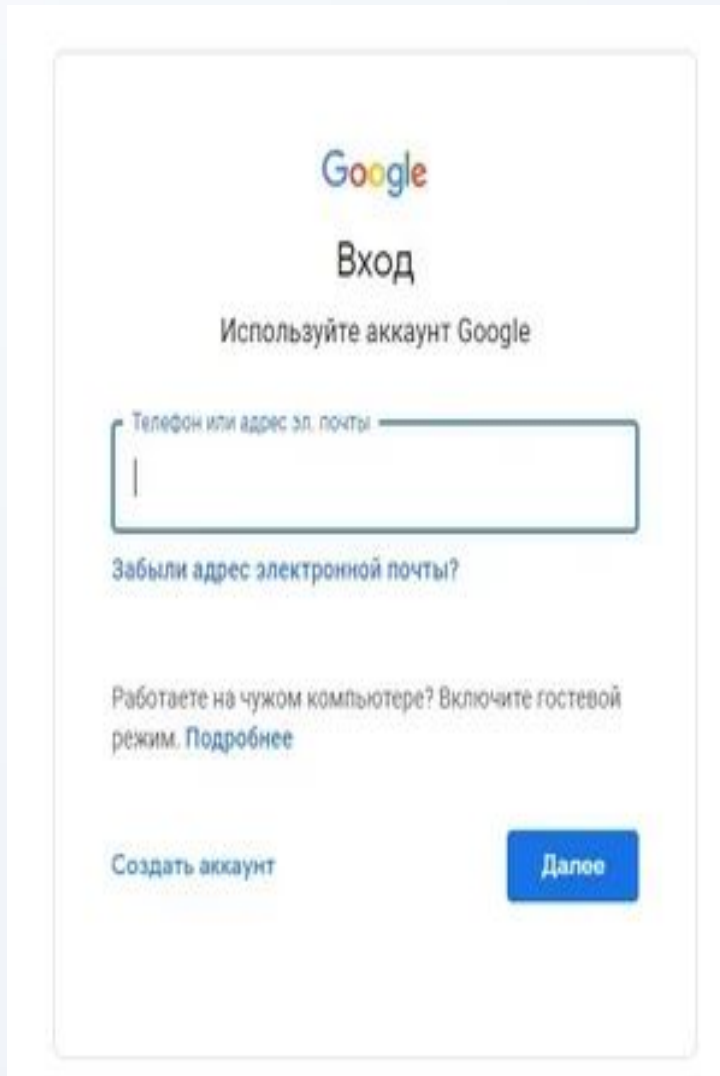
Знание: Пароль или ПИН-код.

Владение: Токен, смартфон, карта.

Биометрия: Отпечаток, лицо, сетчатка.

Важно: Неудачные попытки входа логируются так же тщательно, как и успешные.

Примеры многофакторной аутентификации



Google

Вход

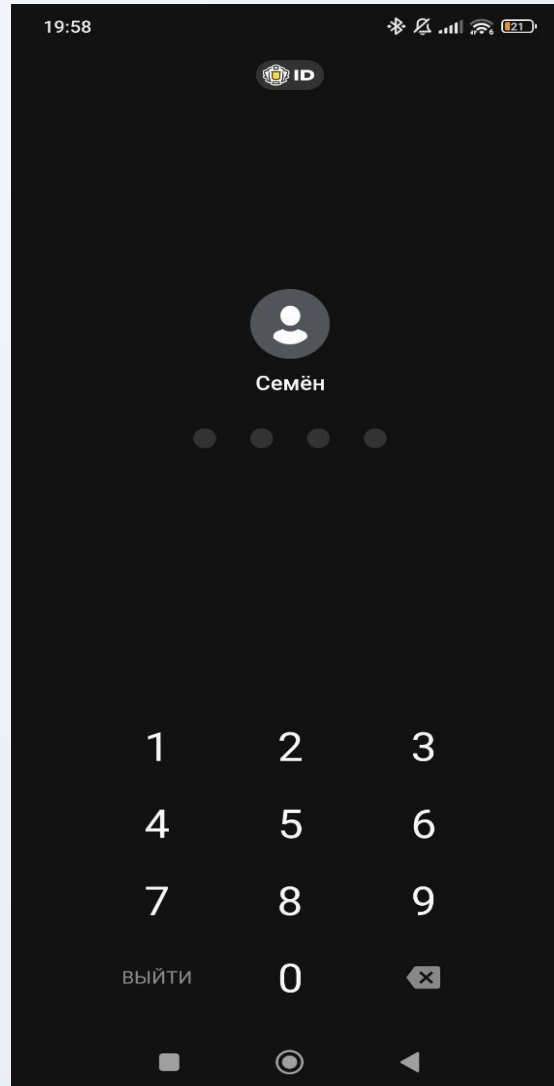
Используйте аккаунт Google

Телефон или адрес эл. почты

Забыли адрес электронной почты?

Работаете на чужом компьютере? Включите гостевой режим. [Подробнее](#)

[Создать аккаунт](#) [Далее](#)



19:58 ID

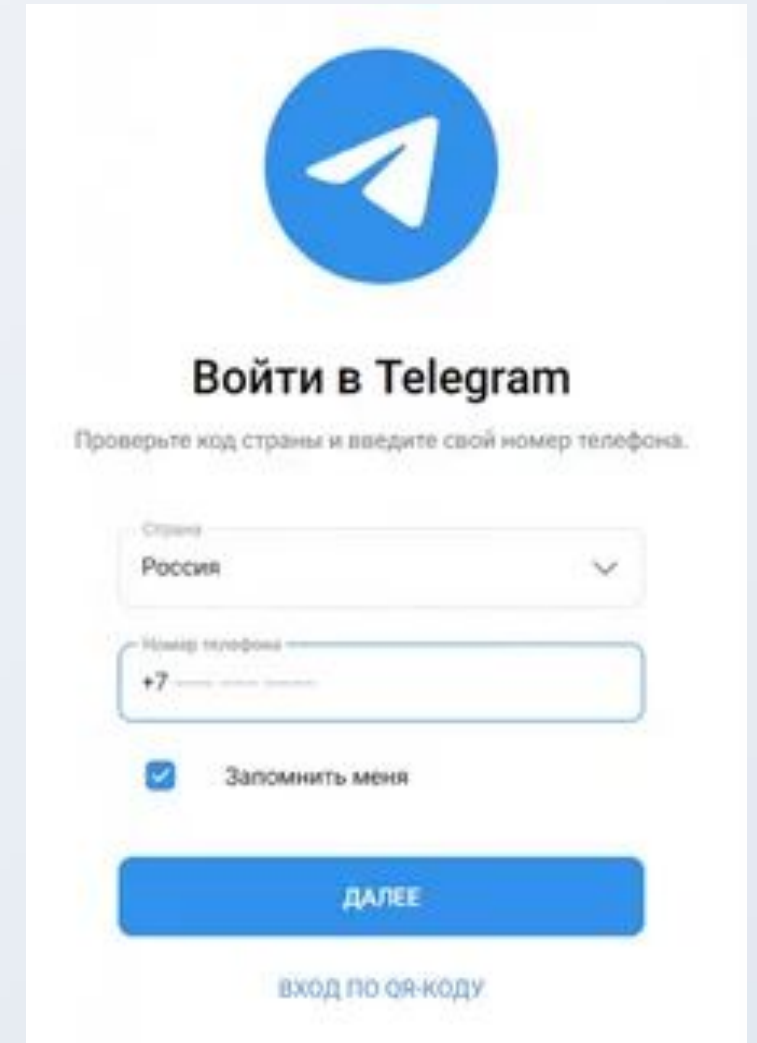
Семён

1 2 3

4 5 6

7 8 9

ВЫЙТИ 0 ✕



Войти в Telegram

Проверьте код страны и введите свой номер телефона.

Страна
Россия

Номер телефона
+7

☒ Запомнить меня

[ДАЛЕЕ](#)

[вход по QR-коду](#)

Сравнение моделей контроля доступа

Модель	Описание	Преимущества	Пример
DAC (Избирательная)	Владелец сам назначает права	Гибкость, простота	chmod в Linux
MAC (Мандатная)	Система решает по меткам	Высшая безопасность	SELinux, гостайна
RBAC (Ролевая)	Права привязаны к ролям	Масштабируемость	Роль «Бухгалтер»
ABAC (Атрибутная)	На основе контекста и атрибутов	Максимальная точность	Доступ по IP и времени

Зачем нужно журналирование?



Расследование

Восстановление цепочки событий
после инцидента.



Комплаенс

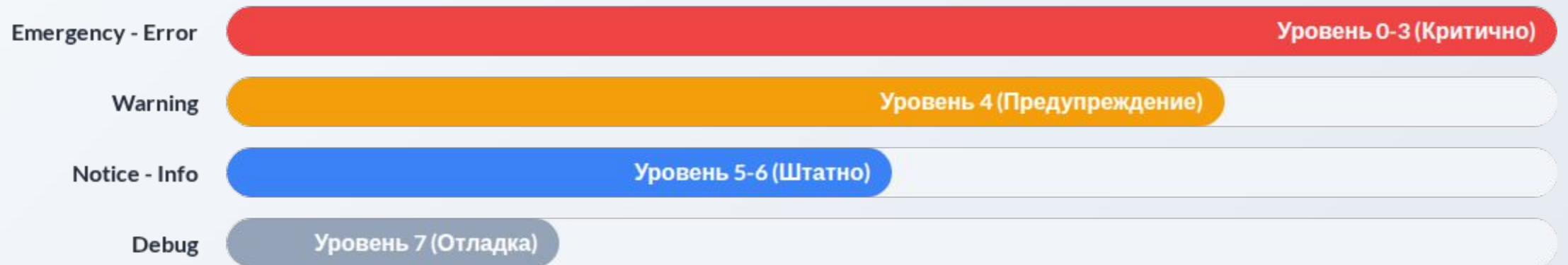
Соответствие стандартам (GDPR,
PCI DSS, ФСТЭК).



Мониторинг

Выявление сбоев, аномалий и
попыток атак в реальном времени.

Уровни важности логов (Syslog)



Централизованная архитектура

Путь данных события:

- 1 **Источники:** Приложения, ОС, БД, сеть.
- 2 **Агенты сбора:** Logstash, Fluentd, Filebeat.
- 3 **Хранилище:** Elasticsearch, хранилище SIEM.
- 4 **Анализ:** Kibana, Grafana, дашборды.

Логи должны храниться отдельно и независимо от их источника!



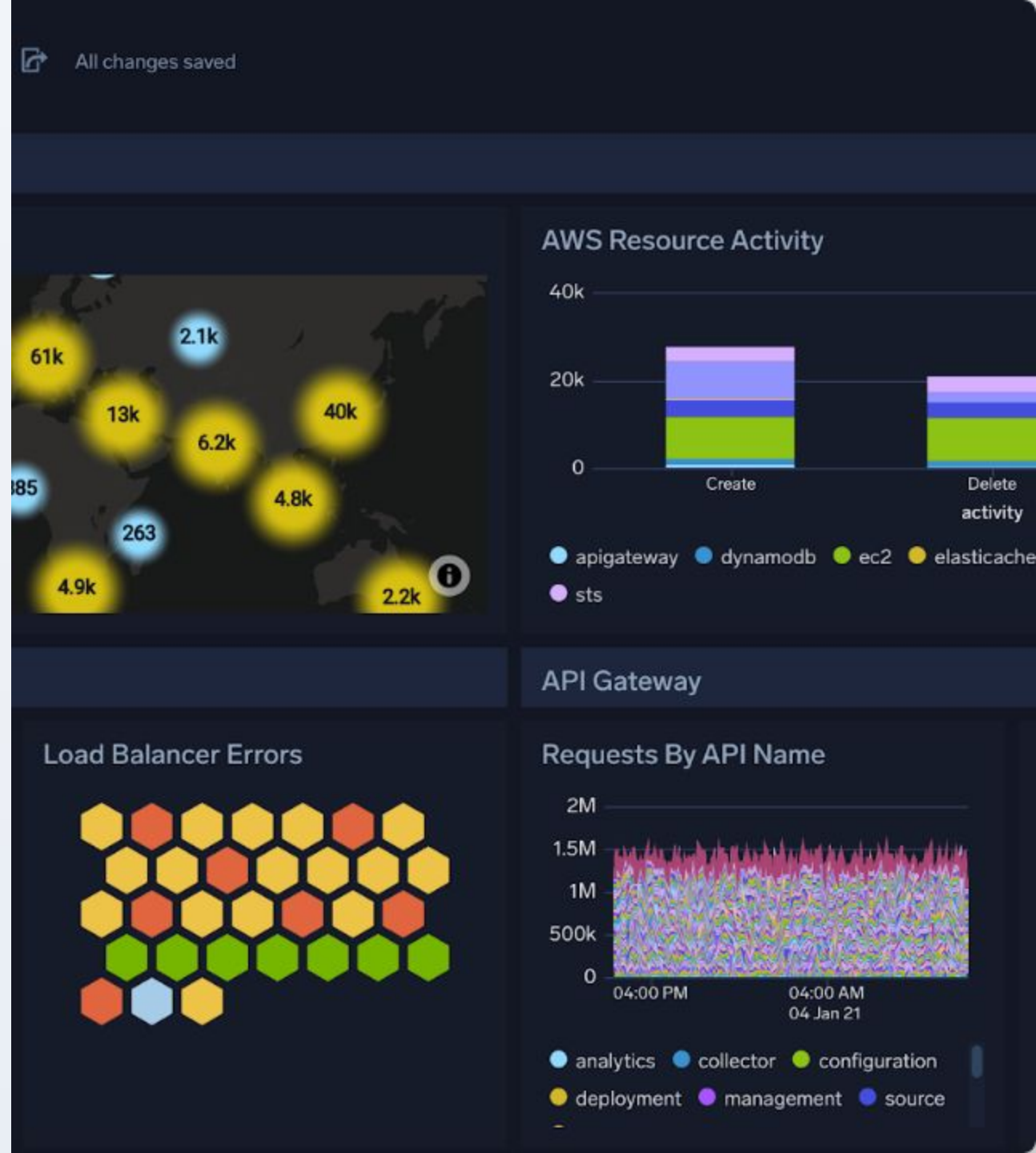
SIEM и защита логов

Security Information and Event Management

SIEM коррелирует события из разных источников для выявления сложных атак (например, перебор паролей + доступ к файлу).

Методы защиты журналов:

- Хеширование и цифровая подпись (Целостность)
- Шифрование (Конфиденциальность)
- WORM-носители (Неизменяемость)



Заключение:

Эффективная информационная безопасность строится на двух взаимодополняющих основах. Контроль доступа выступает в роли превентивного барьера, ограничивая возможности пользователей системой принципов минимальных привилегий и разделения обязанностей. Журналирование и аудит служат механизмом подотчётности и расследования, фиксируя все значимые действия для последующего анализа.